

Ethics, Laws & the Security Profession

The authorization wall

The single line between "hacker" and "professional": **written authorization and clear scope**. Testing systems you do not own, or beyond the scope you were granted, is illegal in almost every jurisdiction.

Key law families:

CFAA (US) – unauthorized access to protected computers

Computer Misuse Act (UK) – unauthorized access / modification

GDPR (EU) – processing personal data without basis

Blue team caution – scanning can itself break laws if unwarranted

IRONY TO AVOID: A "security professional" who runs nmap against a network they do not own commits a crime even when their intent was to help. Always get written scope before scanning.

Responsible disclosure

Coordinated disclosure: inform the vendor, wait a reasonable period (7-90+ days), then publish

Full disclosure: publish immediately – controversial

Bug bounty programs: legally safe, scoped, rewarded testing

Professional ethics principles

Confidentiality of client findings

Do no harm beyond agreed scope

Be honest about capabilities (do not oversell findings)

Never use training tools against real targets

Certification landscape

Path	Focus
Security+	Entry, fundamentals
CEH / PEN-200 (OSCP)	Offensive
CISSP / CISM	Management, governance
GIAC (GSEC, GCIH, etc.)	Hands-on defense
Cloud (CCSP, AWS/Azure Security)	Cloud

Career centers of gravity

SOC analyst → incident responder → threat hunter

Penetration tester → red teamer → exploit developer

GRC analyst → risk manager → CISO

Detection engineer → security engineering lead

Takeaway: Your value as a professional is trust + skill. Skill grows with practice; trust is preserved by scope, honesty and confidentiality. Protect both.

[← MITRE ATT&CK: The Shared Lan...](#)

[Controls, Frameworks & the Def...](#)